

How to add a CVE

How the tool works

The tool evaluates Linux system command output against CVE definitions stored in a browser database (IndexedDB). Each CVE contains identity metadata and detection conditions. A system is marked **VULNERABLE** only when all conditions match simultaneously. If any single condition does not match, the result is **NOT AFFECTED**.

Where to find CVE information

Source	URL	Use for
NIST NVD	nvd.nist.gov	CVE ID, CVSS, official description, and links to vendor advisories.
Vendor advisories	access.redhat.com ubuntu.com/security security.debian.org	Exact affected package versions and remediation commands per distribution.
Qualys Blog	blog.qualys.com	Detailed technical writeups with precise version ranges and detection methods.
oss-security list	openwall.com/lists/oss-security	Original disclosures with raw technical details.
GitHub advisories	github.com/advisories	Best library

Identity and Description Fields

Field	Is required?	What it means	Where to find it	Example
CVE ID	REQUIRED	Unique identifier by MITRE. Must follow the standard format exactly.	NVD page title and URL	CVE-2024-3094
Year	REQUIRED	Year in the CVE ID itself	Read directly from the CVE ID	2024
Name	REQUIRED	Short human-readable name.	Vendor advisory title or create from pattern	XZ Utils Backdoor Dirty Pipe -Kernel Privilege Escalation
Severity	REQUIRED	Qualitative rating based on CVSS. Critical (9-10), High (7-8.9), Medium (4-6.9), Low (0-3.9).	NVD - Displayed next to CVSS	Critical
CVSS Score	REQUIRED	Numerical score 0.0-10.	NVD CVE detail page	10.0 8.1 7.8
Category	REQUIRED	Type of vulnerability	Determine from NVD description	Supply Chain Privileged Escalation Remote Code Execution
Description	REQUIRED	2-4 sentences: what the vulnerability is and how it works.	Rewrite from NVD description and Qualys writeup	A heap overflow in sudo allows any local user to gain root without authentication
Affected Systems	REQUIRED	Which OS, distro, and version ranges are affected.	Vendor advisory – exact package versions per distro	Linux systems running sudo 1.8.2-1.9.5p1
Remediation	REQUIRED	Update commands for both Debian/Ubuntu (apt) and RHEL/Fedora (dnf). Include a verification command	Vendor advisory – patched package version	sudo apt upgrade sudo sudo dnf update sudo sudo --version
References	OPTIONAL	One URL per line. Include the NVD entry at minimum. Add vendor advisories and technical writeups.	Copy from NVD links section	https://nvd.nist.gov/vuln/detail/CVE-2021-3156

Detection Condition

Condition fields

Field	Is required?	What it means?	Example
Label	REQUIRED	Plain-language description of what this condition checks.	XZ Utils version 5.6.0 or 5.6.1 installed
Input field	REQUIRED	Which command output to read.	Packages uname sshd_ldd services log4j
Regex Pattern	REQUIRED	JS regex tested against the input.	liblzma sudo[\s_-]+(1\9\5p1)
Explanation if vulnerable	REQUIRED	Shown when this condition FAIL. Explain what was found and why it indicated vulnerability.	liblzma detected in sshd - backdoor injection path is active.
Explanation if Safe	REQUIRED	Shown when this condition is PASS. Explain what was not found or what safe value was detected.	liblzma is NOT linked into sshd. Hook has no injection path.

Input Field Reference

Field ID	Command	Use for	Example output
uname	uname -a	OS detection, kernel version checks	Linux hostname 5.15.0 x86_64 GNU/Linux
packages	dpkg -l or rpm -qa	Package version checks	ii sudo 1.9.5p1-2 amd64
sshd_ldd	ldd /usr/sbin/sshd	Libraries linked into SSH daemon at runtime	liblzma.so.5 => /lib/x86_64-linux-gnu/liblzma.so.5
services	systemctl list-units --type=service --state=running	Confirming a service is running.	ssh.service loaded active running
log4j	find / -name 'log4j*.jar' 2>/dev/null	Log4Shell CVEs only.	/opt/app/lib/log4j-core-2.14.1.jar

Writing Regex Patterns

The regex pattern is the most technically demanding part. Write it to match vulnerable versions only, not safe ones. The tool uses JavaScript regex with `im` flags (case-insensitive, multiline).

Pattern types

Type	When to use	Example pattern
Simple presence	Checking for a library or service name	liblzma libsystemd ssh
Package version range	Matching vulnerable versions in <code>dpkg -l</code> or <code>rpm -qa</code> . Always include the version number. Never match just the package name.	<code>openssh.*(8\.[0-9] 9\.[0-2])p[0-9]</code> <code>sudo[\s_]+(1\.9\.5p1[^\0-9])</code>
Kernel version range	Matching <code>uname -a</code> output. Add a space before the version to avoid matching sub-strings in longer version numbers.	<code>5\.(8 9 10 11 12 13 14 15 16)\.</code>
File path presence	Matching file paths returned by <code>find</code> . Include the version number when checking for vulnerable library versions.	<code>log4j</code> <code>log4j-core-2\.(0 1 2 3 4 5 6 7 8 9 10 11 12 13 14)\.</code>
OS confirmation	Confirming the operating system before applying other conditions.	Linux Debian Ubuntu

Using the Pattern Tester

1. Enter your pattern in the Regex Pattern field. (Better to type it, not copy-paste it)
2. In the Pattern Tester text area, paste a sample of the actual command output.
3. Click Test Pattern - it shows MATCH or NO MATCH.
4. Test a VULNERABLE sample (should show MATCH) and a SAFE sample (should show NO MATCH)
5. Always test the boundary versions: last vulnerable version AND first safe version.

Step-by-Step: Adding CVE-2023-38408

CVE-2023-38408 is an OpenSSH ssh-agent Remote Code Execution vulnerability (CVSS 9.8, Critical). Affects OpenSSH prior to 9.3p2 when ssh-agent forwarding is used to a compromised server. This walkthrough covers every field from NVD to a saved, verified CVE.

1. Search NIST NVD - *Go to nvd.nist.gov and search CVE-2023-38408*

- CVSS Base Score: 9.8 (Critical)
- Description: A vulnerability in OpenSSH ssh-agent allows RCE when forwarded to a malicious server.
- Affected: OpenSSH prior to 9.3p2

2. Read vendor advisory - *Follow the Red Hat or Debian advisory link from NVD*

- Debian: openssh < 1:9.3p2-1 is affected
- Red Hat: openssh < 9.3p2 is affected
- Patched version: 9.3p2 or later

3. Fill identity fields - *Open the Add CVE tab and complete the top section*

- CVE ID: CVE-2023-38408
- Year: 2023
- Name: OpenSSH ssh-agent RCE
- Severity: Critical
- CVSS Score: 9.8
- Category: Remote Code Execution

4. Fill Description fields - *Write from the NVD description and vendor advisory*

- Description: A vulnerability in OpenSSH ssh-agent allows a remote attacker to execute arbitrary code when agent forwarding is used to a compromised server. Affects OpenSSH prior to 9.3p2.
- Affected Systems: Linux systems running OpenSSH prior to 9.3p2 with ssh-agent forwarding.
- Remediation: Upgrade OpenSSH to 9.3p2 or later.
- Debian/Ubuntu: `sudo apt update && sudo apt upgrade openssh-server`
- RHEL/Fedora: `sudo dnf update openssh`
- Verify: `ssh -V` (must show OpenSSH_9.3p2 or later)
- References: <https://nvd.nist.gov/vuln/detail/CVE-2023-38408>

5. Add Condition 1 / version check - *Click Add Condition. Detects the vulnerable OpenSSH version in installed packages.*

- Label: OpenSSH version prior to 9.3p2
- Input Field: packages
- Regex Pattern: `openssh.*(8\.[0-9]|9\.[0-2])p[0-9]` (type manually)
- Match = Vulnerable: Yes - match means vulnerable
- Explanation if Vulnerable: OpenSSH version prior to 9.3p2 detected. This version is affected by the ssh-agent remote code execution vulnerability.
- Explanation if Safe: OpenSSH version appears to be 9.3p2 or later. Not affected by CVE-2023-38408.
- Pattern Tester - MATCH sample: `ii openssh-server 1:9.2p1-2+deb12u2 amd64`
- Pattern Tester - NO MATCH sample: `e`

6. Add Condition 2 / service check - *Click Add Condition again. Confirms SSH is running and exposes an attack surface.*

- Label: SSH daemon running
- Input Field: services
- Regex Pattern: ssh (type manually)
- Match = Vulnerable: Yes - match means vulnerable
- Explanation if Vulnerable: SSH daemon is active. The attack surface is present on this system.
- Explanation if Safe: SSH daemon not detected as running. No active attack surface even if the vulnerable version is present.
- Pattern Tester - MATCH sample: ssh.service loaded active running OpenBSD Secure Shell server
- Pattern Tester - NO MATCH sample: cron.service loaded active running

7. Save to Database - *Click Save to Database. The CVE now appears in the CVE Library tab*

- A confirmation message appears at the bottom right of the screen.
- Go to CVE Library to verify the entry is correct.
- You can edit or delete it at any time.

8. Verify in Assessment tab - *Go to Assessment tab and paste these inputs to confirm detection works.*

- Installed Packages: ii openssh-server 1:9.2p1-2+deb12u2 amd64
- Running Services: ssh.service loaded active running OpenBSD Secure Shell server
- (Leave all other fields empty - this CVE does not use them)
- Click Run Assessment. CVE-2023-38408 should appear as VULNERABLE.
- Replace the package version with 1:9.3p2-1 and re-run. Should show NOT AFFECTED.